獅子會 App | 缺陷修復與模擬複驗報告

日期：2026-10-14（Asia/Taipei）| 閱讀對象：Hao、Jerry、Tom

1. 本次結論與版本

結論：原列 F01-F10 缺陷已完成本機修正；活動月曆與 7 月制會籍 / 任期一併完成。最後回歸 143/143 項通過，production build 成功。這是本機修復及模擬複驗結果，尚未部署，因此不是正式站的新版本上線簽認。

本報告承接原驗收報告，記錄已實作修正、模擬複驗與新增需求。原 ACCEPTANCE_2026-10-14.md 保留作為修正前紀錄；請勿將其反例測試的 PASS 誤認為功能已修好。

基準：GitHub main 8962dd40c397a37ebbe91e449a84d05684bfcfc0。修改位於本機 codex/acceptance-fixes-2026-10-14；本輪未 commit、push、部署、執行正式 migration 或修改 AWS。正式網站仍不是本輪驗收對象的新版本。

依使用者決策，不等待真實收件信箱或正式測試帳號，改用專用合成會員、活動、假收件匣、可丟棄資料庫完成複驗。這解決測試素材不足，不代表實際 SES 收件、相機硬體、RDS 併發或商店審核已通過。

2. 功能缺陷修復矩陣

編號	已實作修正	複驗與證據範圍
F01 展示帳號	正式環境拒絕公開 demo 身分；即使更改 Email，DEMO-0001 編號仍被拒絕。登入頁移除公開測試憑證。	真實登入路由 + 合成 DB；正式舊帳號 / 雲端權限未由本輪直接修改。正式環境不再接受 0204 這類短密碼，需重設。
F02 晚宴共用 IP	註冊採 IP、Email、邀請多層限額；10 分鐘 IP 1000、Email 5、邀請 2000，仍受 QR 使用上限限制。	同 IP 12 筆真實註冊路由通過；函式測試 200 個不同身分通過。不等同實際晚宴負載容量。
F03 Email 綁定	驗證及重設 token 綁定當時 Email；改址失效舊連結，重寄只讀 DB 現址，不信任 JWT 舊地址。	假收件匣串測註冊、驗證、改址、重寄、舊連結拒絕與單次兌換。
F04 個資保存	地址未實質變更（含大小寫正規化）不清除驗證；改暱稱 / 生日等不強迫重新驗證。	真實 PATCH 路由確認驗證時間保留；真換址才重新驗證。
F05 安全刪帳	刪登入身分及私人資料，以匿名停用會員保留共享活動 / 他人報到。阻擋所有尚有效或預定幹部授權、未開始自建活動。	真實 SQL 驗證他人報到與歷史活動保留、雙裝置失效；頭像改耐久清理工作，非「回應成功就已刪乾淨」。
F06 管理授權	統一 validFrom / validUntil。只有有效 SUPER_ADMIN 全域；非 SUPER 空 scope 不再當全域。	一般、未生效、過期、空 scope、有效 SUPER 權限矩陣；組織循環不致無限遍歷。
F07 批次分派	優先精確 Email；僅唯一匹配才允許大小寫回退。歧義、自己、重複、來源 / 目的超界均阻擋。	真實 SQL 混合成功 / 409，保留版本與理由、稽核紀錄；UI 防舊預覽覆蓋。
F08 報到保存	取消改狀態，不硬刪報名；已報到不可自行取消抹除。重掃保留首次時間與操作者；新增獨立報到稽核。	QR / 人工補登、重掃、已到 / 應到計數、取消釋放名額、保護歷史活動均有回歸。
F09 解除封鎖	個人頁新增獨立「封鎖名單」，可離頁後重新讀取及解除；不自動恢復好友。	真路由測封鎖、名單、雙向隱藏、解除；好友 / 搜尋 / 收件匣不繞過封鎖。
F10 原子限流	每 key + 時窗使用唯一 key 與原子 increment；429 附 Retry-After。	控制交錯測試及隔離 SQL 計數無遺失；不宣稱已完成真 RDS 多連線壓測。

3. 第二輪額外修正

• 全裝置登入撤銷：重設密碼增加 sessionVersion；「登出其他裝置」驗證目前密碼、只更新當前裝置，其餘失效。舊 JWT 在 migration 後需重新登入。

• 郵件連結安全：正式環境只使用設定好的 HTTPS NEXT_PUBLIC_APP_URL，不從任意 request Host 產生含 token 的連結。無設定時安全回報寄信服務尚未就緒。

• 改信箱重複檢查：同時檢查 User / Member 的不分大小寫衝突，避免舊大小寫帳號產生同信箱雙身分。

• 刪活動 / 調容量與檢查同一 Serializable transaction；有簽到紀錄不得刪除。遇同時更新回 409，不默默刪歷史或超收。

• 頭像清理在刪帳後至少等待 6 分鐘，涵蓋先前 5 分鐘有效的上傳連結；具租約、防重複、失敗重試、精確個人 prefix 保護。未排程或 IAM 未設定時工作仍待完成，不假稱 S3 清空。

• 舊待審會員的拒絕 / 通過使用交易與狀態檢查；已有活動、報到、通知或權限歷史者不連帶刪除。郵件於成功提交 DB 後寄出。

• 通知發送的有效身分、權限、好友 / 封鎖及收件人檢查，與建立通知共用交易，避免刪帳後再次寫回個資文字。

• 資歷修改 / 刪除以狀態條件更新，避免在幹部核實後覆寫；審核攜帶更新時間，內容變動須重載核對。

• 寫入 Cookie、封鎖、通知、個資與資歷操作補可信 Origin 檢查；這是網站 Cookie 契約，不是原生 App 登入方案。

4. UI 與長者友善修正

項目	本次調整
U01 / U02 日夜可讀性	危險文字改語意 danger 色；主要按鈕使用 action 色，保留深藍金色品牌。刪帳提醒清楚交代匿名保留與圖片稍後清理。
U03 報到結果	處理中 / 成功 / 重複 / 失敗分開，結果持續保留至下一位；重試同一 QR、名單搜尋、人工原因與本人核對。
U04 表單搜尋	原分會 combobox 補方向鍵、Enter、Escape 與焦點離開整組才收合。註冊必要欄位優先，其他資料可稍後補。
U05 / U06 閱讀與觸控	重要操作回饋至少 16px，細節不再使用 10 / 11px；常用目標以 48px 為設計目標。共用彈窗有標題、焦點圈定、Escape、回焦及忙碌鎖定。
U07 邀請 QR	有效歷史 QR 可重新開啟、放大、下載，不需為展示重發，也不重新露出 token 文字。
U08 批次名單	預覽綁定輸入快照、避免舊回應覆蓋；送出鎖定，混合結果明列，不能把部分失敗當全部成功。
通知收件匣	收到 / 已發送分頁、自己的未讀 / 已讀、直接查看活動；非只剩發送紀錄。
網路失敗	常用頁提供可讀錯誤與重試，不把失敗當空名單；錯誤密碼不應誤導成登入逾時。

以上是已修改的設計與抽樣檢查，不是全站無障礙認證。200% 放大、iOS 原生日期選擇器、暗場相機與實際長者可用性仍需真機 / 真人驗證，不會以程式測試代替。

5. 新增：活動行事曆

活動列表上方新增「活動行事曆」入口，路徑 /events/calendar。可切前月、次月、回本月；月曆顯示有活動日期及數量，點日期查看當日活動，再進活動詳情報名。

日期分組與時間統一 Asia/Taipei，避免手機在海外導致跨日 / 跨月歸錯。沿用同一 /api/events 與會員權限，不建立第二份活動資料。包含無活動、載入、失敗及重試狀態；不另加未經確認的全員活動編輯權限。

6. 新增：7 月 1 日會籍 / 幹部年度

實際日期 / 任期	正確歸屬
2026/06/30	25-26 會籍（2025/07/01 至 2026/06/30）
2026/07/01	26-27 會籍（2026/07/01 至 2027/06/30）
2026 起始幹部年度	2026/07/01 至 2027/06/30，一年一任期
只有 2026 年、未知月份	月份待補，會籍年度未定；不默認 7 月

入會資歷新增實際月份欄位 MemberExperience.startMonth，不更動舊資料年份、不猜舊月份。職務的 startYear 仍是任期起始年度，endYear 仍是最後一任的起始年度，保留既有多年度紀錄。現任是狀態，不代表自動無限延長任期。

資歷頁、會員頁及審核頁共用年度格式；獅齡以已知入會月份對應會籍年度計算。會員自行申報的入會資歷不直接覆蓋幹部維護的 Member.joinYear / joinMonth；實際核實後再依營運規則補登。資歷職務也不等於系統管理權限，不能因填任期自動授權。

7. 可重跑測試與驗證邊界

測試使用真實 TypeScript 路由與 Prisma，在全量 migration 建立的獨立 PGlite PostgreSQL/WASM 資料庫操作。每次獨立建庫；不讀正式 .env、不取 Secrets、不連 RDS / SES / S3。Cookie、郵件與儲存空間是測試 adapter，寄信只允許 example.test 假地址。

執行入口：

```
npm run test:onboarding
```

```
npm run test:simulation
```

```
npm run test:demo
```

```
npm run build
```

本機 UI 模擬：以安全假 DB / Secret 環境建置及啟動 Next，再執行 npm run simulation:preview -- --port 3196 --frontend-port 3195，開啟 http://localhost:3196/__simulation。角色切換經真登入 API，只有隨機測試裝置 cookie，無正式憑證。假信箱在 /__simulation/inbox。服務只綁 loopback、不對外公開；停止服務後資料消失，請勿輸入個資。

本次結果：TS 單元 / 服務測試 109/109、真 API / SQL 與隔離預覽安全模擬 21/21、既有隔離展示測試 13/13，共 143/143 通過；Next.js production build、Prisma schema 與型別檢查通過。測試故意模擬一次寄信失敗，出現「Password reset email failed」是預期錯誤案例，不是漏修失敗。預覽測試的 SIMULATION_ROUTE_NOT_ALLOWED 也是刻意確認未知 API 被拒絕。

手機 UI 抽查：390×844 及 320×740 CSS px；月曆 390px 七天完整可見，320px 只在月曆區內橫滑，頁面寬度不溢出。確認前後月份 / 今天、點日期顯示兩場活動、活動詳情入口；6 月與 7 月表單提示分別顯示 25-26 / 26-27；有效歷史 QR 重開與 Escape 回焦；人工核對補登由 0/1 更新至 1/1，成功訊息保留；通知標已讀及獨立封鎖名單可開啟。日夜畫面存證在 output/acceptance/2026-10-14-fixed/。

測試過程另修正隔離預覽代理未放行 Next 動態頁 %5Bid%5D chunk 的問題，避免合成活動詳情出現 ChunkLoadError；這是測試代理缺口，未把它誤判為正式資料庫錯誤。

8. Jerry 部署交接（尚未執行）

1. 先確認正確環境、備份及目前 migration status；不要 reset 或重跑 seed。新 migration 為 20261014090000_acceptance_security_and_history。

2. 先套用新 migration、generate client，再部署本次程式；migration 包含 sessionVersion、token Email、deletedAt、startMonth、清理工作、報到稽核及限制性外鍵。不得只上新版程式而缺欄位。

3. 此 migration 故意使舊登入需重登、舊未綁 Email 的驗證 / 重設連結失效；請先公告。未改既有密碼，但正式環境短密碼不能登入，需使用重設。

4. 設定可信 HTTPS NEXT_PUBLIC_APP_URL、寄信來源、AWS 區域、頭像 bucket。確認非 SUPER 角色 scope，不自動把空 scope 升為全域；未來生效角色不能提前用。

5. 安排可信背景工作消化 AccountDeletionCleanup 的 PENDING / FAILED / 逾時 PROCESSING。隨附 scripts/run-account-deletion-cleanup.mjs 預設只預覽，需明確環境、DB 與刪除 opt-in 才執行。刪帳後至少等待 6 分鐘再掃；監控失敗，不讓個資圖片永久滯留。

6. 定期清除過期 RateLimitAttempt 時窗，保留合理排查期限；避免熱路徑全表清除。這項維護作業未自動安裝至 AWS。

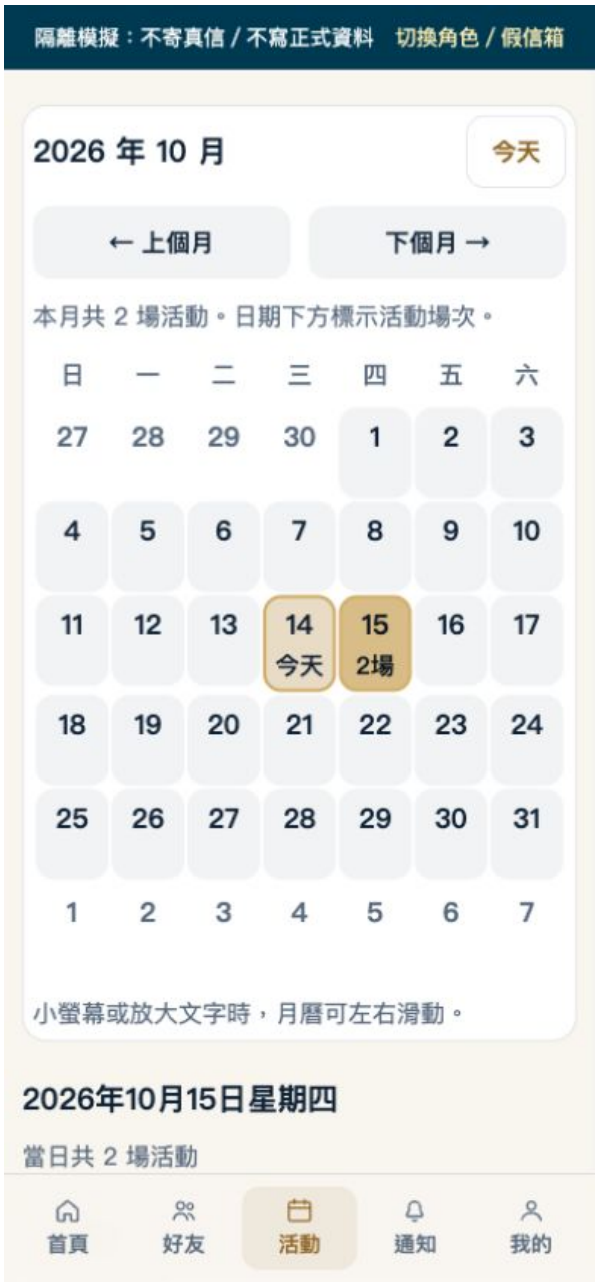
7. 確認資料保存政策：共享活動、報到與受限稽核保留匿名錨點；稽核理由 / 活動自由文字可能有歷史個資，需限制存取、訂保存期及人工處理管道。本次不是全歷史文字自動清洗。

8. 實際 smoke test：正式 SES 收件與驗證回流、S3 上傳與刪帳清理、兩台真裝置、相機拒絕 / 恢復、同網路大量加入、release SHA。需測專用資料，非真會員破壞性測試。

App Store / Android 原生工程、簽章、商店資料、公開隱私 / 客服頁與真機結果並未因此完成；本輪不宣稱已可提交或已上架。

畫面存證 A | 活動月曆日夜模式

390 × 844 CSS px，合成帳號與合成活動。可辨識日期、活動場次及月份切換；320px 另外驗證僅月曆內橫滑，整頁不溢位。



淺色模式



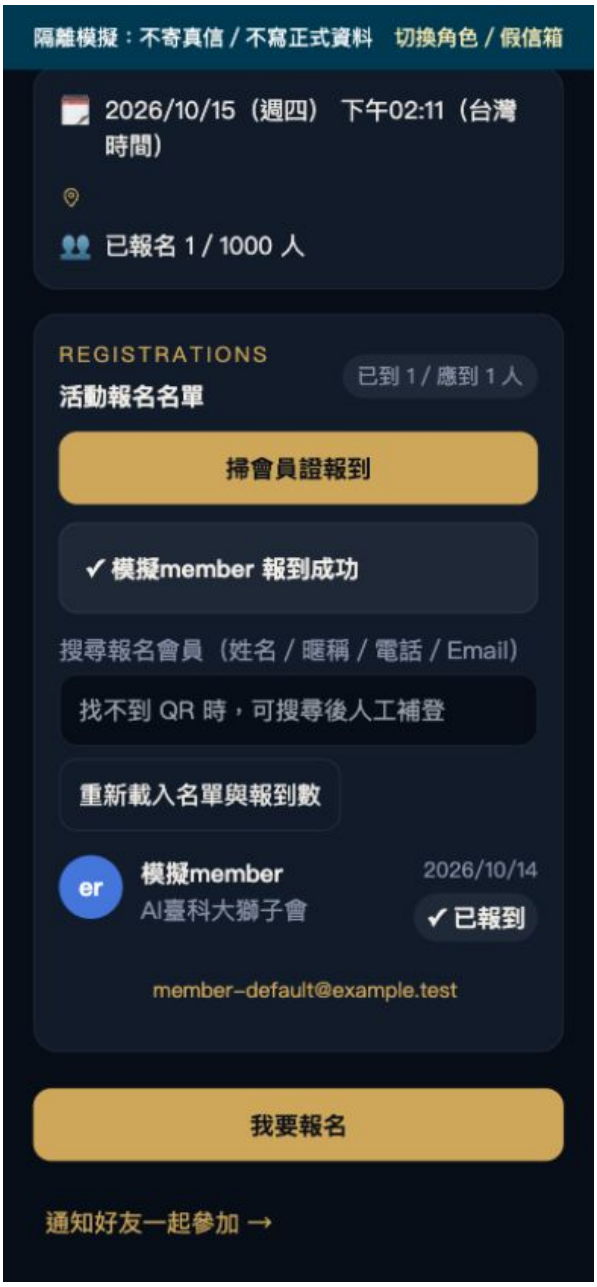
深色模式

畫面存證 B | 會籍年度與人工報到

左：2026 年 6 月正確顯示 25-26 會籍；幹部任期依 7/1 至隔年 6/30。右：人工核對補登後顯示成功，已到 / 應到由 0/1 更新為 1/1。



資歷頁（合成資料）



人工補登成功（合成資料）